

II.A.1 Threats

According to the National Institute of Standards and Technology (NIST), a threat is any circumstance or event with the potential to create loss.¹² A threat can be a natural occurrence, technology or physical failure, a person with intent to harm, or a person who unintentionally causes harm. Information about threats is available from public and private sources. Public sources include the news media, blogs, government publications and announcements, and various websites. Private sources include information security vendors and information-sharing organizations.

The threat identification process is a means to collect data on potential threats that can assist management in its identification of information security risks. Threat modeling is a structured approach that enables an institution to aggregate and quantify potential threats. Institutions should consider using threat modeling to better understand the nature, frequency, and sophistication of threats; evaluate the information security risks to the institution; and apply this knowledge to the institution's information security program. As threats evolve rapidly, however, it is understood that modeling may not account for attacks that have not previously been seen, such as zero-day attacks, but could have significant impacts.

II.A.2 Vulnerabilities

A vulnerability is a weakness in an information system, system security procedure, internal control, or implementation that could be exploited by a threat source.¹³ A technical vulnerability can be a flaw in hardware, firmware, or software that leaves an information system open to potential exploitation. These flaws provide opportunities for hackers to gain access to a computer system, execute commands as another user, or access data contrary to specified access restrictions. Institutions can use automated vulnerability scanners to scan their computer systems for known security exposures, as well as services available from third parties, such as the Mitre Corporation's Common Vulnerability and Exposures (CVE),¹⁴ to track vulnerabilities.

In addition to technology-based vulnerabilities, weaknesses in business operational processes can create security vulnerabilities, exposing financial institutions to unwarranted risk. These vulnerabilities can include weaknesses in security procedures, administrative controls, physical layout, or internal controls that could be exploited to gain unauthorized access to information or to disrupt critical services. For example, an institution's systems architecture may be designed based on management's assumption that manual validation of wire transfers takes place before execution, when in practice the business process does not perform that validation until after transfers have taken place.

¹² NIST SP (Special Publication) 800-30, revision 1, "Information Security: Guide for Conducting Risk Assessments," September 2012.

¹³ Ibid.

¹⁴ CVE is a dictionary of publicly known information security vulnerabilities and exposures. The Mitre Corporation maintains the system. CVE is sponsored by the U.S. Computer Emergency Readiness Team in the Office of Cybersecurity and Communications at the U.S. Department of Homeland Security.

In addition to the vulnerabilities within a financial institution's system, vulnerabilities may also arise from interdependent and interconnected systems. Financial institutions connect their systems through mergers and acquisitions and through relationships with third parties. Over time, as these systems become increasingly interdependent and complex, new vulnerabilities may be introduced. Moreover, financial institutions are dependent on a vast array of hardware and services that may result in vulnerabilities from their supply chains, including those found in hardware and software products.

Management should assess whether the institution has processes and procedures in place to identify and maintain a catalogue of relevant vulnerabilities, determine which pose a significant risk to the institution, and effectively mitigate and monitor the risks posed by those vulnerabilities. When management cannot or chooses not to mitigate a vulnerability, management should document the decision to accept the risk, the level of risk associated with the vulnerability, and the person accountable for accepting the risk. Refer to the "Security Operations" section of this booklet for more information.

II.A.3 Supervision of Cybersecurity Risk and Resources for Cybersecurity Preparedness

II.A.3(a) *Supervision of Cybersecurity Risk*

Cybersecurity is the process of protecting consumer and bank information by preventing, detecting, and responding to attacks. As part of cybersecurity, institutions should consider management of internal and external threats and vulnerabilities to protect information assets and the supporting infrastructure from technology-based attacks. In light of the increasing volume and sophistication of cybersecurity threats, examiners should focus on cybersecurity preparedness in assessing the effectiveness of an institution's overall information security program.

II.A.3(b) *Resources for Cybersecurity Preparedness*

The FFIEC members issued a voluntary Cybersecurity Assessment Tool¹⁵ to help institution boards and management identify risks to their institutions and evaluate their institution's cybersecurity preparedness. In addition, there are other resources available to help management develop and evaluate information security and cyber resilience, such as the NIST Cybersecurity Framework, common approaches developed by the Mitre Corporation, and the U.S. Computer Emergency Readiness Team's (US-CERT)¹⁶ National Cyber Awareness System. Institution management can select a single framework or use a combination of resources to help identify its risks and determine its cybersecurity preparedness. Regardless of the source, frameworks can help management identify a cybersecurity and resilience posture that is commensurate with the institution's risk and complexity.

¹⁵ Refer to the [Cybersecurity Assessment Tool](#) on the FFIEC website.

¹⁶ US-CERT, of the Department of Homeland Security, responds to major incidents, analyzes threats, and exchanges critical cybersecurity information with trusted partners around the world.

II.B Risk Measurement

Action Summary

Management should develop risk measurement processes that evaluate the inherent risk to the institution.

The risk measurement process should be used to understand the institution's inherent risk and determine the risk associated with different threats. Management should use its measurement of the risks to guide its recommendations for and use of mitigating controls.

Threat analysis tools assist in understanding and supporting the measurement of information security-related risks. Such tools can include event trees,¹⁷ attack trees,¹⁸ kill chains,¹⁹ and other security-related schemata.²⁰ These tools help management deconstruct an event into stages, better understand the event, identify the most effective and efficient means of mitigating risk, and improve the information security program. Additionally, management could use a taxonomy for security-related events to help accomplish the following:

- Map threats and vulnerabilities.
- Incorporate legal and regulatory requirements.
- Improve consistency in risk measurement.
- Highlight potential areas for mitigation.
- Select proper controls to cover various attack stages, channels, and assets.
- Allow comparisons among different threats, events, and potential mitigating controls.

Refer to the *IT Handbook's* "Management" booklet for more information.

¹⁷ An event tree is a diagram of a chronological series of events in a system or activity that displays sequence progression, end states, and dependencies across time.

¹⁸ An attack tree is a diagram showing how an asset, or target, might be attacked through various attack scenarios. Using an attack tree helps describe threats on computer systems and possible attacks to realize those threats.

¹⁹ A kill chain originally was used as a military concept related to the structure of an attack. In information security, a kill chain is a method for modeling intrusions on a computer network.

²⁰ Security-related schemata are lists of software vulnerabilities and include the Mitre Corporation's Common Attack Pattern Enumeration and Classification, CVE, Common Weakness Enumeration, "ATT&CK Matrix," and Malware Attribute Enumeration and Characterization, and Mandiant's Open Indicators of Compromise.

II.C Risk Mitigation

Action Summary

Management should develop and implement appropriate controls to mitigate identified risks.

Once management has identified and measured the risks, it should develop and implement an appropriate plan to mitigate those risks. This plan should include an understanding of the extent and quality of the current control environment. When conducting an evaluation of the strength of controls, or the ability to mitigate risk, the institution should consider the system of controls rather than any discrete control.

Management should also obtain, analyze, and respond to information from various sources (e.g., Financial Services Information Sharing and Analysis Center [FS-ISAC]) on cyber threats and vulnerabilities that may affect the institution. Management should incorporate available information on cyber events into the institution's information security program. Additionally, management should develop, maintain, and update a repository of cybersecurity threat and vulnerability information that may be used in conducting risk assessments and provide updates to senior management and the board on cyber risk trends.

II.C.1 Policies, Standards, and Procedures

Information security policies, standards, and procedures should define the institution's control environment through a governance structure and provide descriptions of required, expected, and prohibited activities. Policies, standards, and procedures guide decisions and activities of users, developers, administrators, and managers and inform those individuals of their information security responsibilities. Policies, standards, and procedures should also specify the mechanisms through which responsibilities can be met. In addition, they should provide guidance on acquiring, designing, implementing, configuring, operating, maintaining, and auditing information systems. Policies, standards, and procedures that address the information security program should describe the roles of the information security department, lines of business, and IT organization in administering the information security program. Information security policies, standards, and procedures form the means by which the objectives of the information security program are achieved. Key attributes that contribute to the success of information security policies, standards, and procedures include the following:

- Scope that describes the expectations for appropriate actions by affected parties.
- Sufficient details to guide behavior.
- Implementation through ordinary means, such as system administration procedures and acceptable use policies.
- Enforcement through security tools and restrictions.
- Delineation of the areas of responsibility for users, developers, administrators, and managers.
- Clear and easily understandable communications to all affected parties.
- Certification that employees have read and understand the policies.

- Flexibility to address changes in the environment.
- Annual board review and approval.

II.C.2 Technology Design

While technology can introduce risk, it can also serve as a mitigation tool. Management should understand the benefits and limitations of the technology that the institution uses and whether other types of controls are necessary to compensate for those limitations.

Information security issues arise when (a) the design of the technology and the policies governing its use do not effectively defend against identified and unidentified threats, (b) threats change in ways not envisioned by the designers, and (c) the controls are not operating as intended. Management should continually assess the capability of the institution's processes, people, and technologies to sustain the appropriate level of information security based on the institution's risk profile, size, complexity, and risk appetite.

II.C.3 Control Types

Management may mitigate information security risks by implementing controls. Controls may be categorized according to timing and nature.

Table 1: Examples of Timing- and Nature-Related Controls

Timing		
Control type	Description	Example
Preventive	Controls designed to prevent incidents from occurring	Access controls to applications and systems that prevent unauthorized individuals from performing transactions
Detective	Controls designed to alert management when incidents occur	Reports that show suspicious activity
Corrective	Controls that lessen impact to the institution when adverse incidents occur	Business continuity plans
Nature		
Control type	Description	Example
Administrative	Controls that align with the board-approved risk appetite and inform employees of management's expectations	Policies or procedures that guide implementation of the information security program
Technical	Software or hardware (or both) that prevents unauthorized activity	A firewall that prevents unauthorized logical access to or from a network
Physical	Devices to prevent unauthorized physical access to a facility or computer system	A deadbolt lock on a door

It is important to have a layered control system, which deploys different controls at different points of a business process and throughout an IT system so that the strength of one control can

compensate for weaknesses in or possible failure of another control. Therefore, layered controls function in an integrated fashion to more effectively mitigate risk.

Economic and technical considerations generally affect prevention and detection or response choices in system design. Compensating controls are controls that adjust for weaknesses within the system or process. An example of compensating controls would be a review of activity logs for applications that do not allow proper segregation of duties.

II.C.4 Control Implementation

Management should implement controls that align security with the nature of the institution's operations and strategic direction. Based on the institution's risk assessment, the controls should include, but may not be limited to, patch management, asset and configuration management, vulnerability scanning and penetration testing, end-point security, resilience controls, logging and monitoring, and secure software development (including third-party software development). In implementing controls, management should ensure it has the necessary resources, personnel training, and testing to maximize the effectiveness of the controls.

The level at which controls are implemented should depend on the institution's size, complexity, and risk profile, but all institutions should implement appropriate controls. In light of increasing cybersecurity risks, management should implement risk-based controls for managing cybersecurity threats and vulnerabilities, such as interconnectivity risk. Management should review and update the security controls as necessary depending on changes to the internal and external operating environment, technologies, business processes, and other factors.

The institution can reference one or more recognized technology frameworks and industry standards. Several organizations have published control listings in addition to implementation guidance, including the following:

- **NIST 800 series of publications.** These publications provide descriptions of some management processes and technical guidance on many individual controls.
- **Control Objectives for Information and Related Technology (COBIT).** COBIT provides a broad and deep framework for governance and management of enterprise IT.
- **IT Infrastructure Library (ITIL).** ITIL provides a list of recognized practices for IT service management.
- **International Organization for Standardization (ISO)²¹ 27000 series.** The ISO 27000 series provides control standards specific to information security.
- **Industry publications and sources.²²** Management and staff may find these useful for discrete controls and processes.

²¹ ISO is an independent, non-governmental, international organization that brings together experts to share knowledge and develop voluntary, consensus-based, market-relevant international standards.

²² Some industry publications or organizations that provide security-related information include the ISACA Journal, SANS Institute, the Financial Services Roundtable, the Council on Cybersecurity, and the Open Web Application Security Project.

- **Vendor-provided publications, bulletin boards, and user groups.** Vendors often publish recommendations for securing their products. Additionally, some offer bulletin boards and user groups for clients to interact among themselves.

II.C.5 Inventory and Classification of Assets

Action Summary

Management should inventory and classify assets, including hardware, software, information, and connections.

Management should maintain and keep updated an inventory of technology assets that classifies the sensitivity and criticality of those assets, including hardware, software, information, and connections. Management should have policies to govern the inventory and classification of assets both at inception and throughout their life cycle, and wherever the assets are stored, transmitted, or processed. Inventories enable management and staff to identify assets and their functions. Classification enables the institution to determine the sensitivity and criticality of assets. Management should use this classification to implement controls required to safeguard the institution's physical and information assets. Additionally, management can use the inventory to discover specific vulnerabilities, such as unauthorized software.

Inventories are important for management to identify assets that require additional protection, such as those that store, transmit, or process sensitive customer information, trade secrets, or other information or assets that could be a target of cyber criminals. Knowing what information assets the institution has and where they are stored, transmitted, or processed helps management comply with federal and state laws and regulations regarding privacy and security of sensitive customer information.

After inventorying the assets, management should classify the information according to the appropriate level of protection needed. For example, systems containing sensitive customer information may require access controls based on job responsibilities. These systems should have stronger controls than systems containing information meant for the general public. Some institutions classify information as public, non-public, or institution-confidential, while others use the classifications high, moderate, and low. Additional classifications, such as critical and noncritical, may be helpful to certain types of institutions.

II.C.6 Mitigating Interconnectivity Risk

Business processes often require institutions to share information with other institutions and third-party service providers that require connectivity. The extent of interconnectivity is a function of network architecture, network complexity, traffic volume, and number of connections. Interconnectivity risk arises from misuse, mismanagement, or compromise of these connections.

To mitigate interconnectivity risk, management should do the following:

- Identify connections with third parties, including other financial institutions, financial institution intermediaries, and third-party service providers.
- Identify all access points and connection types that pose risk, such as local area network (LAN) connections to other networks or Internet service providers (ISP), Wi-Fi, and cellular connections.
- Identify connections between and access across low-risk and high-risk systems.
- Assess all connections with third parties that provide remote access capability or control over internal systems.
- Implement and assess the adequacy of controls to ensure the security of connections regardless of criticality or sensitivity.

Management should maintain network and connectivity diagrams and data flow charts to ensure adequacy of layered controls and to facilitate more timely recovery and restoration of systems when incidents occur.

II.C.7 User Security Controls

Action Summary

Management should mitigate the risks posed by users by doing the following:

- Establishing and administering security screening in IT hiring practices.
- Establishing and administering a user access program for physical and logical access.
- Employing segregation of duties.
- Obtaining agreements covering confidentiality, nondisclosure, and authorized use.
- Providing training to support awareness and policy compliance.

Users should be granted access to systems, applications, and databases based on their job responsibilities. Access rights should be granted in accordance with the institution's physical and logical access control policies. Authorized users with elevated or administrator privileges can pose a potential threat to systems and data. Employees, contractors, or third-party service providers can exploit their legitimate computer access for unauthorized purposes. Additionally, the degree of internal access granted to some users increases the risk of damage or loss of information and systems. Risk exposures from internal users include the following:

- Alteration of data.
- Deletion of production and backup data.
- Misdirected data.
- Disruption of systems.
- Destruction of systems.
- Misuse of systems for personal gain or to damage the institution.
- Appropriation of strategic or customer data for espionage or fraud schemes.
- Extortion for stolen data.
- Misuse of data following the termination or change in job responsibility of an employee.

Management should understand the risks to the institution's information-processing environment and establish appropriate user access controls to mitigate these and other potential risks to the institution's assets. Users should understand and confirm their understanding of their roles and responsibilities in maintaining a sound security environment, which includes both physical and logical areas.

II.C.7(a) *Security Screening in Hiring Practices*

Management should have a process to verify job application information for all new employees. The sensitivity of a particular job or access level may warrant additional screening and recurring background and credit checks. Management should verify that contractors are subject to similar screening procedures. In addition to initial screening, management should remain alert to changes in personal circumstances of employees and contractors that could increase incentives for system misuse or fraud.

II.C.7(b) *User Access Program*

Management should develop a user access program to implement and administer physical and logical access controls to safeguard the institution's information assets and technology. This program should include the following elements:

- Principle of least privilege, which recommends minimum user profile privileges for both physical and logical access based on job necessity.
- Alignment of employee job descriptions to the user access program.
- Requirements for business and application owners to define user profiles.
- Ongoing reviews by business line and application owners to verify appropriate access based on job roles with changes reported on a timely basis to security administration personnel.
- Timely notification from human resources to security administrators to adjust user access based on job changes, including terminations.
- Periodic independent reviews that ensure effective administration of user access, both physical and logical.

For more information, refer to the "Physical Security" and "Logical Security" sections of this booklet.

II.C.7(c) *Segregation of Duties*

Segregation of duties, or job designs that require more than one person to complete critical or sensitive tasks, can help mitigate risk. Employees and third parties with access to sensitive resources could cause substantial damage and potential loss. System administrators, for instance, have the most powerful role in the user access process and have unlimited access to an institution's information assets and technology. Given this extensive access, management should evaluate the process for determining which individuals should be granted system administrator privileges. Such access should be appropriately monitored for unauthorized or inappropriate activity. Management should incorporate independent reviews or approvals for individuals who

perform multiple functions to minimize the potential for fraud, irregularities, and errors. Examples of segregation of duties include the following:

- Independent monitoring of the activities performed by the users with increased privileges (e.g., system administrators and super users²³).
- Distribution of system administration activities so no administrator can hide his or her activities or control an entire system.
- Additional levels of approval as the criticality and sensitivity of decisions increase.

If an activity is conducted without appropriate segregation of duties, management should require an independent review (e.g., audit) of that activity.

II.C.7(d) Confidentiality Agreements

The institution should protect the confidentiality of customer and institution information. A breach in confidentiality could disclose proprietary information, increase fraud risk, damage the institution's reputation, violate customer privacy and associated rights, and violate laws or regulations. Confidentiality agreements can be used to put all parties on notice that the financial institution owns its information, expects strict confidentiality, and prohibits information sharing outside of that required for legitimate business needs. Management should obtain signed confidentiality agreements before granting employees and contractors access to IT systems.

II.C.7(e) Training

Training ensures personnel have the necessary knowledge and skills to perform their job functions.²⁴ Training should support security awareness and strengthen compliance with security and acceptable use policies. Ultimately, management's behavior and priorities heavily influence employee awareness and policy compliance, so training and the commitment to security should start with management. Management should educate users about their security roles and responsibilities and communicate them through acceptable use policies. Management should hold all employees, officers, and contractors accountable for complying with security and acceptable use policies and should ensure that the institution's information and other assets are protected. Management should have the ability to impose sanctions for noncompliance.

Training materials for most users focus on issues such as end-point security, log-in requirements, and password administration guidelines. Training programs should include scenarios capturing areas of significant and growing concern, such as phishing and social engineering attempts, loss of data through e-mail or removable media, or unintentional posting of confidential or proprietary information on social media. As the risk environment changes, so should the training. The institution should collect signed acknowledgments of the employee acceptable use policy as part of the annual training program.

²³ In computing, the super user is a special user account used for system administration. Depending on the operating system, the name of this account might be root, administrator, admin, or supervisor.

²⁴ See also Information Security Standards, section III.C.2, requiring each financial institution to train staff to implement its information security program.